

Threat Model

OpenMRS LegacyUI Module — IN-B2.4 Security

Project	IN-B2.4 Security — Avans Hogeschool HBO-ICT
Module	legacyui-audit (OpenMRS Platform 2.0.0 + LegacyUI)
Datum	2026-06-09
Versie	v2 — bijgewerkt na Attack Surface Mapping (Sprint 3, maatregel 8.25)
Methodiek	STRIDE (NEN-7510:2024-2 bijlage B)
Norm	NEN-7510:2024-2 maatregel 8.25 (Veilige ontwikkeling)
Invoer voor	Risicomatrix (WS03) en bow-tie diagrammen (WS04)

Dit document beschrijft het dreigingsmodel voor de OpenMRS LegacyUI-module op basis van broncode-analyse. De STRIDE-methode is toegepast conform NEN-7510:2024-2 bijlage B. Alle dreigingen zijn voorzien van numerieke risicoscores (kans × impact, schaal 1–5). **Versie 2** integreert 8 nieuwe threats (TM-N1 t/m TM-N8) en 3 uitbreidingen (TM-W1 t/m TM-W3) die zijn voortgekomen uit de Attack Surface Mapping (Sprint 3, maatregel 8.25). Nieuwe en bijgewerkte items zijn gemarkeerd.

Markering	Betekenis
[NIEUW]	Nieuw geïdentificeerde dreiging (Attack Surface Mapping v2)
[BIJGEWERKT]	Bestaande dreiging uitgebreid met nieuwe bevindingen
(geen markering)	Oorspronkelijke dreiging uit v1 — ongewijzigd

1. Aanvalsvlak-overzicht (Attack Surface)

1.1 Externe invoerkanalen

Invoerkanaal	Locatie	Opmerking
HTTP-formulievelden	150+ JSP-bestanden (omod/src/main/webapp/)	Naam, BSN, wachtwoord, medische gegevens
Bestandsuploads	moduleList.jsp, obsForm.jsp, addFormResource.jsp	.omod modules, obs-bijlagen, formulierresources
Query-parameters (GET)	q/locationHierarchy, q/message, patientDashboard.form	Zoekterms, patiënt-ID's — XSSFilter dekt GET NIET (zie TM-N8)
DWR/AJAX-parameters	/dwr/*, /ms/call/plaincall/*	JSON-berichten via JavaScript-RPC (15 serviceklassen); geen method-level authz
Omgevingsvariabelen	runtime.properties, Global Properties (DB)	DB-wachtwoorden, systeemconfiguratie — schrijfbaar door alle ingelogde gebruikers (TM-N3/N4)
HL7-berichten	/admin/hl7/*, /remotecomunication/postHl7.form	Medische berichten; credentials in POST-body (TM-N5)
downloadURL (SSRF)	ModuleManagementController.java: 50-53, ModuleListController.java:112	Server-Side Request Forgery — intern netwerk bereikbaar (TM-N1/N2) [NIEUW]

1.2 Hoog-risico eindpunten samengevat

Risico	Invoervalidatie				Voornaamste dreiging
	Eindpunt	Privilege	Autorisatie		
■	fetchModuleDetails.form	Impliciet (admin-area)	Geen	Geen privilege-check	SSRF (TM-N1) [NIEUW]
■	postHl7.form	POST-body credentials	Geen	In-band auth	Plaintext creds + HL7-injectie (TM-N5) [NIEUW]
■	DWRAdministrationService.se tGlobalProperty	Geen	Geen	Geen privilege-check	Config-manipulatie (TM-N3) [NIEUW]
■	globalProps.form	isAuthenticated()	Geen	Alleen isAuthenticated()	Privilege-escalatie + log-sabotage (TM-N4) [NIEUW]
■	/forgotPasswordForm	Geen (publiek)	Minimaal	Geen	Account-overname via geheime vraag (S3)
■	module.list (upload)	MANAGE_MODULES	Geen type-validatie	Ja	RCE via .omod (T2) + SSRF-download (TM-N2) [NIEUW]
■	/admin/users/user.form	EDIT_USERS	Beperkt	Ja — geen CSRF	Privilegeverhoging, CSRF (E1)
■	/patientDashboard.form	Authenticatie	Nee	isAuthenticated()	BSN/dossier-exposure (I2)
■	/dwr/* (15 services)	Authenticatie	Geen per methode	Sessie — geen method-level	CSRF, BSN-lek, XSS (T3/I2)
■	/admin/maintenance/systemInfo.htm	Authenticatie	n.v.t.	isAuthenticated()	Versiegegevenslek (I1/TM-N6)
■	rebuildSearchIndex.htm	isAuthenticated()	n.v.t.	Alleen isAuthenticated()	DoS-vector (TM-N7) [NIEUW]

2. Vertrouwensmodel (Trust Boundaries)

#	Grens	Aanwezige controles	Ontbrekende controles	NEN-7510
VG1	Internet ↔ Nginx	TLS verplicht · /openmrs/admin/ geblokkeerd extern · Rate-limiting vereist	■ Rate-limiting niet geconfigureerd	8.20, 8.21
VG2	Nginx ↔ OpenMRS-app	HTTP intern (Docker) · Sessie-validatie per verzoek via OpenMRS Context	■ CSRF ontbreekt op alle POST-eindpunten (G1) · XSSFilter dekt GET niet (TM-N8)	8.25
VG3	OpenMRS Core ↔ MySQL	JDBC intern Docker-netwerk · Poort 3306 nooit extern · Credentials via .env	■ Data-at-rest encryptie niet bevestigd	5.33, 8.24
VG4 [NIEUW]	OpenMRS-app ↔ Internet (uitgaand)	—	■ Geen SSRF-beveiliging op uitgaande HTTP-verzoeken (fetchModuleDetails + downloadURL)	8.20, 8.28

Kritieke keten 1 (DWR): Internet → Nginx → DwrFilter → OpenmrsDWRServlet → [15 DWR-services] → OpenMRS Core → MySQL
Geen CSRF-token, geen method-level autorisatie op elke stap na VG1 (NEN 8.25 gap G1/G4)

Kritieke keten 2 (RCE): Internet → Nginx → ModuleManagementController → ModuleFactory.loadModule() → JVM-executie
Geen bestandstype-validatie → potentieel RCE (NEN 8.8, 8.25 gap G3)

Kritieke keten 3 (SSRF) [NIEUW]: Internet → Nginx → fetchModuleDetails/downloadURL → java.net.URL.openStream() → Intern netwerk
Geen URL-whitelist → Server-Side Request Forgery naar intern netwerk of cloud-metadata (NEN 8.20, 8.28)

3. STRIDE Dreigingsidentificatie

Risicoscore = Kans (1–5) × Impact (1–5). Kleurcodering: ■ Rood ≥ 16 (Kritiek) ■ Oranje 10–15 (Hoog) ■ Geel 7–9 (Midden) ■ Groen <7 (Laag) | [NIEUW] = Sprint 3 Attack Surface Mapping [BIJGEWERKT] = uitgebreide bestaande dreiging

S — Spoofing

S1 — Brute-force aanval op inlogpagina		Risicoscore: 16 — Kritiek
Component	/login (LoginController)	
Beschrijving	Geen rate-limiting, account-lockout of CAPTCHA. Aanvaller kan geautomatiseerd wachtwoorden uitproberen zonder geblokkeerd te worden.	
Bewijs	LoginController.java — geen vertraging, geen lockout-logica aangetroffen in broncode	
Kans	4 (Hoog)	
Impact	4 (Hoog)	
NEN-7510	8.5 (Veilige authenticatie), 8.25 (Veilige ontwikkeling)	

S2 — Session hijacking via onversleutelde verbinding		Risicoscore: 15 — Hoog
Component	Nginx reverse proxy, OpenMRS sessiemanagement	
Beschrijving	Docker-compose stelt poorten 8081/8082/8083 bloot op HTTP. Geen HTTPS-redirect aanwezig. Sessie-tokens onderschepbaar via MITM.	
Bewijs	docker-compose.yml: HTTP-poorten blootgesteld; geen HTTPS-redirect in Nginx-config	
Kans	3 (Midden)	
Impact	5 (Kritiek)	
NEN-7510	8.24 (Gebruik van cryptografie), 8.20 (Netwerkbeveiliging)	

[BIJGEWERKT]

S3 — Account-overname via geheime vraag (wachtwoordherstel)		Risicoscore: 12 — Hoog
Component	/forgotPasswordForm (ForgotPasswordFormController)	
Beschrijving	Wachtwoordherstel via geheime vraag is gevoelig voor social engineering en woordenboek-aanvallen. Drie verschillende responsepaden creëren een enumeratie-oracle: (1) niet-bestaande gebruiker → neep-vraag; (2) gebruiker zonder secret question → auth.question.empty; (3) gebruiker met question → echte vraag. Tijdelijk wachtwoord heeft geen vervaldatum.	
Bewijs	ForgotPasswordFormController.java:131-145, 171-175 — response-divergentie voor bestaande/niet-bestaande users; herstel niet gelogd (gap 8.15-6)	
Kans	3 (Midden)	
Impact	4 (Hoog)	
NEN-7510	8.5 (Veilige authenticatie), 8.15 (Logging)	
Wijziging	TM-W2: uitgebreid met drie enumeratie-paden en ontbrekende logging van wachtwoordherstel.	

[NIEUW]

TM-N5 — Plaintext credentials in HTTP-body via postHI7.form

Risicoscore: 16 — Kritiek

Component	/remotecomunication/postHI7.form (PostHI7Controller)
Beschrijving	PostHI7Controller accepteert username en password als POST-parameters buiten het sessiemodel om. Credentials zijn kwetsbaar voor logging-interceptie, proxy-capturing en credential-harvesting. Na authenticatie worden HL7-berichten zonder inhoudsvalidatie in de wachtrij geplaatst.
Bewijs	PostHI7Controller.java:38-45 — username/password als POST-params; HL7-berichtinhoud niet gevalideerd
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	A.8.5 (Beveiligde authenticatie), A.8.25

T — Tampering

T1 — Cross-Site Request Forgery (CSRF) op alle POST-eindpunten

Risicoscore: 16 — Kritiek

Component	Alle POST-eindpunten: user.form, settings.form, modules/manage, obs.form
Beschrijving	Geen CSRF-tokens in JSP-formulieren of Spring-configuratie. Een aanvaller kan via een kwaadaardige website een geauthenticeerde gebruiker POST-verzoeken laten sturen.
Bewijs	userForm.jsp, changePasswordForm.jsp, login.jsp — geen CSRF-token; geen Spring Security CSRF-filter in config.xml
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	8.25 (Veilige ontwikkeling — sessiebeveiliging)

T2 — Remote Code Execution via kwaadaardige .omod-upload

Risicoscore: 10 — Hoog

Component	/admin/modules/manage/ (ModuleManagementController, moduleList.jsp)
Beschrijving	Geen bestandstype-validatie aanwezig. Een kwaadaardig .omod-bestand wordt als Java-code uitgevoerd in de JVM.
Bewijs	moduleList.jsp r.151: multipart upload zonder type-validatie; geen MIME-check aangetroffen
Kans	2 (Laag)
Impact	5 (Kritiek)
NEN-7510	8.25 (Veilige ontwikkeling), 8.8 (Technische kwetsbaarheden)

T3 — Cross-Site Scripting (XSS) via DWR-parameters

Risicoscore: 12 — Hoog

Component	/dwr/*, /ms/call/plaincall/* (15 DWR-serviceklassen)
Beschrijving	XSSFilter dekt reguliere HTTP-verzoeken maar DWR gebruikt eigen request-dispatching. Niet aantoonbaar dat XSSRequestWrapper ook DWR-parameters filtert.
Bewijs	XSSFilter.java wraps non-GET; DwrFilter.java routeert /dwr/* intern — filterchain-dekking onbevestigd
Kans	3 (Midden)
Impact	4 (Hoog)
NEN-7510	8.25 (Output-encoding, inputvalidatie)

[NIEUW]

TM-N1 — SSRF via fetchModuleDetails.form Risicoscore: 16 — Kritiek

Component	GET /admin/modules/manage/fetchModuleDetails.form?url=
Beschrijving	De parameter url wordt zonder enige validatie als new java.net.URL(url).openStream() verwerkt. Aanvaller kan interne hostnames, cloud-metadata-endpoints (169.254.169.254) of interne API's bereiken.
Bewijs	ModuleManagementController.java:50-53 — geen URL-validatie, geen privilege-check in methode
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	A.8.20 (Netwerken beveiligen), A.8.25, A.8.28 (Veilig programmeren)

[NIEUW]

TM-N2 — SSRF via downloadURL bij module-upload Risicoscore: 16 — Kritiek

Component	POST /admin/modules/module.list (action=upload, download=true)
Beschrijving	ModuleUtil.getURLStream(url) wordt aangeroepen zonder URL-validatie. Heeft wel een MANAGE_MODULES-check, maar de URL wordt niet gesanitiseerd.
Bewijs	ModuleListController.java:112-120 — geen URL-whitelist op downloadURL-parameter
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	A.8.20, A.8.25, A.8.28

[NIEUW]

TM-N3 — Schrijftoegang systeemconfiguratie via DWR zonder privilege-check Risicoscore: 16 — Kritiek

Component	DWR-service /dwr/* → DWRAdministrationService.setGlobalProperty(name, value)
Beschrijving	setGlobalProperty bevat geen privilege-check. Iedere geauthenticeerde gebruiker kan via DWR globale properties overschrijven, inclusief beveiligingsinstellingen (brute-force-drempel, wachtwoordbeleid, log-niveaus, SMTP-configuratie).
Bewijs	DWRAdministrationService.java:36-38; config.xml:199-203 — geen Context.requirePrivilege aanwezig
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	A.8.3 (Toegangsbeperking), A.8.5 (Beveiligde authenticatie), A.8.25

[NIEUW]

TM-N4 — Systeemconfiguratie wijzigbaar door elke ingelogde gebruiker via globalProps.form Risicoscore: 16 — Kritiek

Component	POST /admin/maintenance/globalProps.form
Beschrijving	GlobalPropertyController.onSubmit controleert uitsluitend Context.isAuthenticated(), niet een specifiek privilege. Via as.purgeGlobalProperties kunnen properties worden verwijderd. Via OpenmrsUtil.applyLogLevels() kan de logging-configuratie worden gemanipuleerd (beveiligings-event-logging uitzetten).
Bewijs	GlobalPropertyController.java:70, 109-121 — alleen isAuthenticated(), geen MANAGE_GLOBAL_PROPERTIES-check
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	A.8.3, A.8.15 (Logging-configuratie manipuleerbaar), A.8.25

[NIEUW]

TM-N8 — XSSFilter beschermt GET-parameters niet Risicoscore: 9 — Midden

Component	Alle GET-endpoints (o.a. findPatient.htm?name=..., portlets met request-params)
Beschrijving	XSSFilter past encoding uitsluitend toe op niet-GET-verzoeken (!'GET'.equalsIgnoreCase(...)). GET-parameters worden niet gesanitiseerd door de applicatielaag. Reflected XSS is mogelijk via GET-parameters die in JSP-pagina's worden weergegeven.
Bewijs	XSSFilter.java:31 — expliciet GET-verzoeken overgeslagen
Kans	3 (Midden)
Impact	3 (Midden)
NEN-7510	A.8.28 (Veilig programmeren), A.8.25

R — Repudiation

[BIJGEWERKT]

R1 — Ontbrekende auditlogging voor beveiligingsgebeurtenissen Risicoscore: 20 — Kritiek

Component	Alle controllers, DWR-services, ForcePasswordChangeFilter
Beschrijving	Geen expliciete auditlogging voor kritische handelingen: inlogpogingen, wachtwoordwijzigingen, gebruikersaanmaken, module-uploads, logout-events. Uitgebreid: ook DWR-schrijfacties (obs, programma's, relaties, global properties) laten geen audit-spoor achter.
Bewijs	LoginController, ChangePasswordFormController, UserFormController, ModuleManagementController, LogoutServlet.doGet:37-47 — geen security-event logging aangetroffen. DWRObsService.createObs, DWRRelationshipService, DWRProgramWorkflowService, DWRAdministrationService.setGlobalProperty — niet gelogd.
Kans	5 (Hoog — structureel ontbrekend)
Impact	4 (Hoog)
NEN-7510	8.16 (Monitoringactiviteiten), 5.33 (Bescherming van registraties), 8.15 (Logging)
Wijziging	<i>TM-W3: uitgebreid met DWR-schrijfacties (obs, relaties, programma's, global properties) en logout-event als nieuwe niet-gelogde gebeurtenissen.</i>

I — Information Disclosure

I1 — Versiegegevens bereikbaar via systeem informatiepagina

Risicoscore: 12 — Hoog

Component	/admin/maintenance/systemInfo.htm (SystemInformationController)
Beschrijving	Versienummers van OpenMRS-componenten, Java-versie en serverinformatie zichtbaar voor alle geauthenticeerde gebruikers. Vereenvoudigt gerichte CVE-exploitatie.
Bewijs	SystemInformationController.java:40 — versiedetails zonder specifieke privilege-check voor rol
Kans	4 (Hoog)
Impact	3 (Midden)
NEN-7510	8.8 (Beheer van technische kwetsbaarheden)

I2 — Patiëntgegevens en BSN blootgesteld via DWR AJAX

Risicoscore: 15 — Hoog

Component	/dwr/* — DWRPatientService, DWRPersonService, DWRObsService
Beschrijving	Zonder method-level autorisatie kan elke geauthenticeerde gebruiker alle patiënten opvragen, ongeacht GET_PATIENTS-privilege.
Bewijs	config.xml r.69-82: findPatients, getPatient, getSimilarPatients in allowlist; geen per-method privilege-check
Kans	3 (Midden)
Impact	5 (Kritiek)
NEN-7510	8.2 (Bevoorrechte toegangsrechten), 8.25 (Autorisatiecontrole)

I3 — HL7-berichten bevatten onversleutelde medische gegevens

Risicoscore: 8 — Midden

Component	/admin/hl7/* (HL7InQueueListController, HL7InArchiveListController)
Beschrijving	HL7-berichten in wachtrij en foutarchief bevatten medische patiëntgegevens. Toegang vereist slechts basisauthenticatie.
Bewijs	HL7InQueueListController — geen specifiek HL7-privilege aantoonbaar
Kans	2 (Laag)
Impact	4 (Hoog)
NEN-7510	8.24 (Gebruik van cryptografie), 5.33 (Bescherming van registraties)

[NIEUW]

TM-N6 — Information Disclosure via serverLog.form en systemInfo.htm

Risicoscore: 9 — Midden

Component	GET /admin/maintenance/serverLog.form; GET /admin/maintenance/systemInfo.htm
Beschrijving	Beide controllers bevatten geen expliciete privilege-check op controller-niveau. Serverlogbestanden bevatten stacktraces, SQL-queries, gebruikersnamen en interne padstructuren.
Bewijs	ServerLogController.java:66 en SystemInformationController.java:40 — geen controller-niveau privilege-check
Kans	3 (Midden)
Impact	3 (Midden)
NEN-7510	A.8.3 (Toegangsbeperking), A.8.25

D — Denial of Service

D1 — Geen rate-limiting op authenticatie-eindpunten

Risicoscore: 16 — Kritiek

Component	/login (LoginController), /forgotPasswordForm
Beschrijving	Geen account-lockout of tijdelijke blokkering bij herhaalde mislukte pogingen. Maakt brute-force én opzettelijke account-lockout DoS mogelijk.
Bewijs	LoginController — geen lockout-mechanisme aangetroffen
Kans	4 (Hoog)
Impact	4 (Hoog)
NEN-7510	8.5 (Veilige authenticatie), 8.25 (Veilige ontwikkeling)

D2 — Onbeperkte bestandsupload-grootte

Risicoscore: 6 — Laag

Component	/admin/modules/manage/, /admin/observations/obs.form, /admin/forms/addFormResource
Beschrijving	Geen maximale bestandsgrootte aanwezig. Aanvaller met uploadprivilege kan serveropslag en geheugen uitputten.
Bewijs	moduleList.jsp: multipart-formulier zonder size-restrictie; geen MaxUploadSizeExceededException-handler aangetroffen
Kans	2 (Laag)
Impact	3 (Midden)
NEN-7510	8.25 (Inputvalidatie — invoergrootte)

[NIEUW]

TM-N7 — DoS-vector via rebuildSearchIndex.htm

Risicoscore: 9 — Midden

Component	POST /admin/maintenance/rebuildSearchIndex.htm
Beschrijving	Iedere ingelogde gebruiker kan een resource-intensieve herindexering starten zonder specifieke privilege-eis. Herhaalde aanroepen kunnen de server overbelasten.
Bewijs	SearchIndexController.java:49-55 — alleen isAuthenticated(), geen privilege-check of rate-limiting
Kans	3 (Midden)
Impact	3 (Midden)
NEN-7510	A.8.6 (Capaciteitsbeheer), A.8.25

E — Elevation of Privilege

E1 — Aanmaken beheerdersaccount via UserFormController

Risicoscore: 15 — Hoog

Component	/admin/users/user.form (UserFormController)
Beschrijving	Bij succesvolle CSRF-aanval of gecompromitteerd EDIT_USERS-account kan aanvaller een nieuw beheerdersaccount aanmaken of bestaande rollen escaleren.
Bewijs	UserFormController r.200-227: role-assignment via formulier; EDIT_USERS-check aanwezig maar geen CSRF-beveiliging
Kans	3 (Midden)
Impact	5 (Kritiek)
NEN-7510	8.2 (Bevoorrechte toegangsrechten), 8.25 (Autorisatiecontrole)

E2 — Volledig systeemcompromis via .omod RCE (gecombineerd met T1/S1) Risicoscore: 10 — Hoog

Component	/admin/modules/manage/ (ModuleManagementController)
Beschrijving	Via CSRF (T1) of brute-force (S1) gevolgd door kwaadaardige .omod-upload geeft aanvaller volledige controle over server, database en alle patiëntgegevens.
Bewijs	moduleList.jsp r.151-155: upload actief zonder validatie; ModuleFactory.loadModule() voert Java-code uit
Kans	2 (Laag)
Impact	5 (Kritiek)
NEN-7510	8.25 (Veilige ontwikkeling), 8.8 (Technische kwetsbaarheden), 8.2 (Bevoorrechte toegang)

[BIJGEWERKT]

TM-W1 — Uitbreiding ontbrekende autorisatie op controller-niveau (uitgebreide scope) Risicoscore: 12 — Hoog

Component	GlobalPropertyController, SystemInformationController, ServerLogController, SearchIndexController, SettingsController, DWR-laag
Beschrijving	Het bestaande threat model beschreef ontbrekende privilege-checks voor AdminPageFilter en UserFormController. De attack surface mapping toont dat dit patroon breder aanwezig is: ook GlobalPropertyController, SystemInformationController, ServerLogController, SearchIndexController en SettingsController missen een expliciete privilege-check op controller-niveau.
Bewijs	GlobalPropertyController.java:70, ServerLogController.java:66, SystemInformationController.java:40, SearchIndexController.java:55 — alle alleen isAuthenticated()
Kans	3 (Midden)
Impact	4 (Hoog)
NEN-7510	A.8.3 (Toegangsbeperking)
Wijziging	TM-W1: scope van gap 8.3-4/5 uitgebreid naar 5 extra controllers; systematisch patroon bevestigd.

4. NEN-7510:2024-2 Maatregel 8.25 — Gap-analyse

Maatregel 8.25 vereist: inputvalidatie op type/formaat/lengte, autorisatiecontroles, output-encoding, en correcte CSRF-bescherming en sessiemanagement.

#	Gap	Ernst	Aanbevolen maatregel
G1	Geen CSRF-bescherming op alle POST-eindpunten	Kritiek	Implementeer Spring Security CSRF-tokens op alle POST-formulieren
G2	Geen rate-limiting op /login en /forgotPasswordForm	Hoog	Nginx limit_req_zone op authenticatie-eindpunten
G3	Geen bestandstype-validatie bij module-upload	Kritiek	Valideer MIME-type + extensie; overweeg digitale handtekening voor .omod
G4	Geen method-level autorisatie op DWR-services	Hoog	GET_PATIENTS op DWRPatientService.findPatients(); GET_OBS; GET_USERS; MANAGE_GLOBAL_PROPERTIES op setGlobalProperty
G5	Geen invoerlengtebeperking op DWR-parameters	Hoog	Voeg maximale lengtevalidatie toe per DWR-methode
G6	Ontbrekende auditlogging voor beveiligingsgebeurtenissen	Hoog	Log inlogpogingen, wachtwoordwijzigingen, module-uploads, DWR-schrijfacties, logout via OpenMRS Log4j (de 5 W's)
G7	Versiegegevens bereikbaar voor alle gebruikers	Midden	Beperk /admin/maintenance/systemInfo tot specifiek privilege (SYSTEM_DEVELOPER)
G8	Kwetsbaar wachtwoordherstelmechanisme	Midden	Vervang geheime vraag door e-mail/OTP-gebaseerd herstel
G9 [NIEUW]	Geen SSRF-beveiliging op uitgaande HTTP-verzoeken	Kritiek	URL-whitelist op fetchModuleDetails.form en downloadURL; blokkeer RFC-1918 adressen; privilege-check op methode-niveau toevoegen
G10 [NIEUW]	Plaintext credentials in HTTP-body (postHl7.form)	Kritiek	Migreer naar token-/sessie-gebaseerde authenticatie voor HL7-integratie; verwijder credential-parameters uit request-body
G11 [NIEUW]	setGlobalProperty zonder privilege-check (DWR)	Kritiek	Context.requirePrivilege(MANAGE_GLOBAL_PROPERTIES) in beide DWR-methoden; audit-log op property-wijzigingen
G12 [NIEUW]	XSSFilter dekt GET-parameters niet	Hoog	XSSFilter uitbreiden naar GET-parameters; output-escaping verifiëren in JSP-templates
G13 [NIEUW]	DoS via rebuildSearchIndex.htm	Midden	Specifieke privilege-check; rate-limiting of mutex op herindexeringstrigger

5. Dreigingentabel — Invoer voor risicomatrix (WS03) en bow-tie (WS04)

Gesorteerd op risicoscore (hoog → laag). Kans × Impact op 5×5 schaal conform vastgestelde risicobereidheid variant B. Nieuwe dreigingen (Sprint 3) zijn gemarkeerd met [N]. Bestaande uitbreidingen met [B].

ID	Dreiging	Component	K	I	Score	Prio	NEN-7510
R1 [B]	Ontbrekende auditlogging (incl. DWR)	Alle controllers + DWR	5	4	20	Kritiek	8.16, 5.33, 8.15
T1	CSRF op alle POST-eindpunten	Alle POST-eindpunten	4	4	16	Kritiek	8.25
S1	Brute-force op inlogpagina	/login	4	4	16	Kritiek	8.5, 8.25
D1	DoS via inlogflooding	/login, /forgotPasswordForm	4	4	16	Kritiek	8.5, 8.25
TM-N1 [N]	SSRF via fetchModuleDetails	ModuleManagementController	4	4	16	Kritiek	8.20, 8.25, 8.28
TM-N2 [N]	SSRF via downloadURL module-upload	ModuleListController	4	4	16	Kritiek	8.20, 8.25, 8.28
TM-N3 [N]	DWR setGlobalProperty zonder privilege	DWRAdministrationService	4	4	16	Kritiek	8.3, 8.5, 8.25
TM-N4 [N]	globalProps.form privilege-check ontbreekt	GlobalPropertyController	4	4	16	Kritiek	8.3, 8.15, 8.25
TM-N5 [N]	Plaintext credentials postHL7.form	PostHL7Controller	4	4	16	Kritiek	8.5, 8.25
S2	Session hijacking via HTTP	Nginx, sessiemanagement	3	5	15	Kritiek	8.24, 8.20
I2	BSN-lek via DWR AJAX	/dwr/*, DWRPatientService	3	5	15	Kritiek	8.2, 8.25
E1	Privilegeverhoging via user.form	/admin/users/user.form	3	5	15	Kritiek	8.2, 8.25
S3 [B]	Account-overname via geheime vraag	/forgotPasswordForm	3	4	12	Hoog	8.5, 8.15
T3	XSS via DWR-parameters	/dwr/*	3	4	12	Hoog	8.25
I1	Versiegegevens lek	systemInfo.htm	4	3	12	Hoog	8.8
TM-W1 [B]	Privilege-checks ontbreken (uitgebreid)	5 extra controllers	3	4	12	Hoog	8.3
T2	RCE via .omod-upload	/admin/modules/manage/	2	5	10	Hoog	8.25, 8.8
E2	Systeemcompromis via .omod RCE	/admin/modules/manage/	2	5	10	Hoog	8.2, 8.8, 8.25
TM-N6 [N]	Info-disclosure serverLog + systemInfo	Maintenance controllers	3	3	9	Midden	8.3, 8.25
TM-N8 [N]	XSSFilter dekt GET niet	Alle GET-endpoints	3	3	9	Midden	8.28, 8.25
TM-N7 [N]	DoS via rebuildSearchIndex	SearchIndexController	3	3	9	Midden	8.6, 8.25
I3	HL7-gegevens onvoldoende afgeschermd	/admin/hl7/*	2	4	8	Midden	8.24, 5.33
D2	Opslag-uitputting via upload	Uploadpunten	2	3	6	Laag	8.25

Gebruik van deze tabel: Kopieer de ID-kolom en risicoscores direct naar de risicomatrix (WS03). De vijf hoogste risico's (R1=20, T1/S1/D1/TM-N1–N5=16) zijn de primaire kandidaten voor bow-tie analyse (WS04). Alle maatregelen zijn gekoppeld aan NEN-7510:2024-2 voor het auditrapport (WS06). [N] = nieuw (Sprint 3 Attack Surface Mapping) [B] = bijgewerkte bestaande dreiging.